COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.2 · Other Social Engineering

Mestre CyberSec · **Lesson 2.2 — Other Social Engineering** (3:29) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Engenharia social além do email: misinformation (desinformação em escala), brand impersonation (falso suporte), pretexting (cenário inventado — 'sou auditor, preciso verificar X'), dumpster diving (papel sensível na lixeira), shoulder surfing.

💡 Key Exam Highlights & Critical Concepts

- Pretexting: cenário FALSO mas plausível que justifica o pedido
- Misinformation: desinformar em escala (rede social) pra favorecer objetivo

🎯 Exam Tips & Typical CompTIA Scenarios

- 'creates a fabricated scenario to obtain information' = pretexting

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.2 — Other Social Engineering)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Pretexting

A social engineering technique where an attacker creates a fabricated but plausible scenario to convince a target to provide information or perform an action.

⚠️ ***Exam Trap:*** *Gatilho: 'creates a fabricated scenario to obtain information' = pretexting. Não confundir com phishing: o pretexto é a história/identidade inventada que justifica o pedido.*

• Misinformation/Disinformation

False or inaccurate information spread to deceive; disinformation is deliberately created and spread, often at scale via social media, to influence opinions or actions.

⚠️ ***Exam Trap:*** *Gatilho: 'informação falsa em escala' ou 'influenciar objetivo' = misinformation/disinformation. Se houver intenção deliberada de enganar, é disinformation; se for erro, misinformation.*

• Brand Impersonation

An attacker pretends to represent a trusted brand, often via fake support, websites, or messages, to trick users into revealing credentials or installing malware.

⚠️ ***Exam Trap:*** *Gatilho: 'falso suporte da Microsoft/Amazon' = brand impersonation. Distinção: usa nome/logo de marca legítima, diferente de impersonation genérica de um indivíduo.*

• Dumpster Diving

Searching through trash or recycling to obtain sensitive information such as documents, credentials, or hardware that were improperly discarded.

⚠️ ***Exam Trap:*** *Gatilho: 'papel sensível na lixeira' = dumpster diving. Contramedida: triturar documentos e destruir mídia; não é ataque técnico, é físico/social.*

• Shoulder Surfing

Observing a user's screen or keyboard input from a nearby position to capture sensitive information such as passwords, PINs, or confidential data.

⚠️ ***Exam Trap:*** *Gatilho: 'olhar por cima do ombro' = shoulder surfing. Contramedida: filtros de privacidade, posicionamento de tela e atenção ao ambiente.*

• Impersonation

Pretending to be someone else, such as a coworker, executive, technician, or authority figure, to gain trust and convince a target to comply with a request.

⚠️ ***Exam Trap:*** *Gatilho: 'fingir ser alguém confiável' = impersonation. Pretexting é a história/cenário; impersonation é a identidade falsa assumida.*

• Typosquatting

Registering a domain name similar to a legitimate one, relying on common typing mistakes, to impersonate a brand and lure users to malicious sites.

⚠️ ***Exam Trap:*** *Gatilho: 'domínio parecido com o original' = typosquatting. Relaciona-se a brand impersonation; verifique URL e use bloqueio de domínios maliciosos.*

• Hoax

A false warning or threat, often spread via email or social media, designed to trick users into taking harmful action or spreading misinformation.

⚠️ ***Exam Trap:*** *Gatilho: 'falso vírus/alerta em corrente' = hoax. Distinção: hoax é uma mentira sobre ameaça; phishing tenta roubar credenciais/dados diretamente.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A payroll administrator receives a phone call from a person claiming to be from the internal audit team. The caller says they are performing a compliance review and needs the administrator to confirm the last four digits of several employees' bank accounts. The caller already knows the payroll manager's name and the current audit schedule from a public filing. The administrator is pressured to help quickly. Which social engineering technique is the caller using?

A) Pretexting

B) Typosquatting

C) Dumpster diving

D) Shoulder surfing

QUESTION 2 · EXAM SCENARIO

Employees receive a message in the corporate collaboration tool from an account named IT Service Desk that uses the company logo and a nearly identical display name. The message says the employee's MFA token must be re-registered and links to it-helpdesk-company.com. Several users enter credentials before security blocks the domain. Which attack best describes this?

A) Business email compromise

B) Brand impersonation

C) Watering hole

D) Credential stuffing

QUESTION 3 · EXAM SCENARIO

A facilities team discovers that locked recycling bins behind an office were forced open overnight. The next week, several employees receive convincing calls referencing internal project codes, old org charts, and vendor invoice numbers. The information referenced was not available online. Which social engineering method most likely provided the attackers with this information?

A) Shoulder surfing

B) Typosquatting

C) Dumpster diving

D) Hoax

QUESTION 4 · EXAM SCENARIO

A sales director works on a confidential merger proposal while waiting in an airport lounge. A person seated behind repeatedly leans forward and appears to watch the laptop screen. Days later, a competitor references merger details in a negotiation. No malware or email compromise is found. Which technique most likely exposed the information?

A) Pretexting

B) Dumpster diving

C) Disinformation

D) Shoulder surfing

QUESTION 5 · EXAM SCENARIO

An employee needs to submit expenses through the company portal. They type the portal name into a search engine and click a sponsored link for company-expenses-portal.com instead of companyexpenses.com. The site looks identical and accepts their corporate credentials. The employee is then redirected to the real portal. Which attack technique is this?

A) Typosquatting

B) Pretexting

C) Hoax

D) Dumpster diving

QUESTION 6 · EXAM SCENARIO

During a merger, an anonymous actor creates a fake internal memo announcing immediate layoffs and posts it on an employee discussion board. The memo uses the CEO's signature and spreads rapidly, causing panic. Security later confirms the memo is false and was created to manipulate employees. Which term best describes this activity?

A) Misinformation

B) Disinformation

C) Pretexting

D) Impersonation

QUESTION 7 · EXAM SCENARIO

Employees receive a forwarded email warning that a new virus will erase all files if they open any PDF attachment. The email urges recipients to delete important shared files and forward the warning to everyone. IT investigates and finds no such virus and no malicious attachment. Which social engineering term best describes this message?

A) Vishing

B) Whaling

C) Hoax

D) Tailgating

QUESTION 8 · EXAM SCENARIO

A help desk technician receives a call from someone claiming to be the CFO. The caller uses the CFO's name, mentions a recent board meeting, and demands an immediate password reset for the CFO's account because they are locked out before a financial report deadline. The technician cannot verify the caller's identity through normal callback. Which social engineering technique is being used?

A) Typosquatting

B) Dumpster diving

C) Misinformation

D) Impersonation

QUESTION 9 · EXAM SCENARIO

A well-meaning employee reads an unverified post in a public forum claiming the company's benefits portal was breached. Without checking with IT, they forward it to dozens of coworkers, causing confusion. The claim is later found false, but the employee did not intend to deceive. Which term best describes the false information spread?

A) Misinformation

B) Disinformation

C) Pretexting

D) Brand impersonation

QUESTION 10 · EXAM SCENARIO

After several incidents in which callers claimed to be auditors, IT support staff, or executives to obtain information, the security team wants to reduce the success of these calls. Which control is most effective for this specific problem?

A) Deploy full-disk encryption on all endpoints

B) Verify identity using pre-established out-of-band contact procedures

C) Enforce least privilege for database service accounts

D) Configure SPF, DKIM, and DMARC

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Pretexting

Pretexting is correct because the caller invents a plausible scenario and role—internal audit/compliance review—to manipulate the employee into disclosing sensitive data. Typosquatting uses lookalike domains, dumpster diving involves discarded materials, and shoulder surfing is direct visual observation.

Question 2: Option B — Brand impersonation

Brand impersonation is correct because the attacker impersonates a trusted internal service desk using logo, display name, and a lookalike support domain. BEC typically involves compromising or spoofing a business email account, a watering hole compromises a website victims visit, and credential stuffing uses previously breached credentials.

Question 3: Option C — Dumpster diving

Dumpster diving is correct because the attackers likely retrieved discarded documents containing internal project codes, org charts, and invoice numbers. Shoulder surfing is visual observation, typosquatting is domain registration abuse, and a hoax is a false warning or rumor.

Question 4: Option D — Shoulder surfing

Shoulder surfing is correct because the information was likely observed directly from the screen in a public place. Pretexting uses a fabricated scenario, dumpster diving uses discarded materials, and disinformation is deliberately false information spread to deceive.

Question 5: Option A — Typosquatting

Typosquatting is correct because the attacker registered a lookalike domain that resembles the legitimate expense portal to capture credentials. Pretexting is a fabricated scenario, a hoax is a false warning, and dumpster diving involves retrieving discarded information.

Question 6: Option B — Disinformation

Disinformation is correct because the false information was deliberately created and spread to manipulate people. Misinformation is false information shared without deceptive intent, pretexting is a fabricated scenario to obtain information, and impersonation is pretending to be a specific person.

Question 7: Option C — Hoax

Hoax is correct because the message is a false warning designed to cause fear and prompt recipients to take unnecessary actions. Vishing is voice phishing, whaling targets senior executives, and tailgating is unauthorized physical entry following an authorized person.

Question 8: Option D — Impersonation

Impersonation is correct because the caller pretends to be a specific executive, the CFO, to obtain a password reset. Typosquatting abuses lookalike domains, dumpster diving retrieves discarded data, and misinformation is false information spread without deceptive intent.

Question 9: Option A — Misinformation

Misinformation is correct because false information was shared without the intent to deceive. Disinformation is deliberately false and intended to mislead, pretexting is a fabricated scenario, and brand impersonation pretends to be a trusted organization or service.

Question 10: Option B — Verify identity using pre-established out-of-band contact procedures

Verifying identity through a pre-established out-of-band contact procedure is correct because it defeats pretexting, impersonation, and vishing attempts that rely on the caller's claimed identity. Full-disk encryption, database least privilege, and email authentication controls do not verify a live phone caller.